

Evaluating Privacy Measures in Healthcare Apps Predominantly Used by Older Adults

Suleiman Saka, Sanchari Das

Department of Computer Science, University of Denver, USA

suleiman.saka@du.edu , sanchari.das@du.edu

Abstract—The widespread adoption of telehealth systems has led to a significant increase in the use of healthcare apps among older adults, but this rapid growth has also heightened concerns about the privacy of their health information. While HIPAA in the US and GDPR in the EU establish essential privacy protections for health information, limited research exists on the effectiveness of healthcare app privacy policies, particularly those used predominantly by older adults. To address this, we evaluated 28 healthcare apps across multiple dimensions, including regulatory compliance, data handling practices, and privacy-focused usability. To do this, we created a Privacy Risk Assessment Framework (PRAF) and used it to evaluate the privacy risks associated with these healthcare apps designed for older adults. Our analysis revealed significant gaps in compliance with privacy standards to such, only 25% of apps explicitly state compliance with HIPAA, and only 18% mention GDPR. Surprisingly, 79% of these applications lack breach protocols, putting older adults at risk in the event of a data breach.

Index Terms—Privacy, Older Adults, Healthcare Apps

I. INTRODUCTION

The use of healthcare apps has soared exponentially in recent years [45], with over 325,000 health-related mobile apps available as of 2022 [28], [44], [52]. The global mobile health market is currently valued at \$181 billion and is anticipated to surpass \$300 billion by 2025 [42]. An important demographic that stands to benefit from this technology are older adults. As this demographic grows [9], more of them are expected to use digital health applications for various needs [3], [6], [10], [15]. However, the rapid development and adoption of such technology raise significant concerns about the privacy of personal health information [40]. Issues such as inadequate compliance with privacy policies [11], [34], [47], [49], and improper data handling highlight the need to assess the efficacy and compliance of app privacy policies to ensure adequate protection of older adults' health information [2], [24], [33], [48], yet remain understudied. To address this, we evaluated the privacy policies of 28 healthcare apps predominantly used by older adults by creating the Privacy Risk Assessment Framework (PRAF). This framework was established on regulations such as the Health Insurance Portability and Accountability Act (HIPAA) [39], [50], [51], [55] and General Data Protection Regulation (GDPR) [1], [35], [43], [46], aiming to identify any concern in the privacy policies that could impact older adults. Our findings reveal significant variability in the comprehensibility and transparency of privacy policies and key privacy principles such as data minimization, retention period,

and breach protocol were unevenly implemented across the apps. Through our analysis, we aimed to answer the following research questions:

- *RQ1: How comprehensible and transparent are healthcare app privacy policies for older adult users?*
- *RQ2: What key principles or protections are missing from app policies when compared to privacy regulations?*
- *RQ3: What key trends emerge from the multi-dimensional privacy risk profiles of healthcare apps for older adults?*

II. BACKGROUND

The growing reliance on healthcare applications and telehealth systems underscores the critical need for robust privacy measures for personal health information [26], [29]. Despite the establishment of regulations such as HIPAA [39], [55] in the United States and the GDPR in the European Union [35], which set forth comprehensive protections for personal health information, there remains a notable gap in research concerning the effective compliance of these measures within healthcare apps targeted at older adults [21], [30], [56]. Existing studies reveal a concerning trend: healthcare apps, especially those aimed at aiding older adults, often lack clear compliance and effective privacy policies [33]. Armontrout et al. reviewed the regulatory framework for mobile mental health apps and discovered that the majority of these apps were not subject to FDA regulation, emphasizing the need for more precise guidelines and standards for app developers [4]. Similarly, Rosenfeld et al. found that most health apps designed for dementia patients fail to incorporate any form of privacy policy, and those that do often present them in a manner that is difficult to comprehend [38]. This observation is echoed by Blenner et al. [7] and Huckvale et al. [23], who pointed out that some apps, including those for managing diabetes and mental health conditions, fall short of transparently communicating their data-sharing practices [22], [37].

Mulder compared app developers' marketing narratives with the content of their privacy policies, uncovering misalignment between promotional claims and actual policy [31]. This discrepancy underscores the urgent need for privacy policies to conform with regulatory requirements, particularly within the healthcare domain. Our study expands on this work by examining HIPAA and GDPR compliance across a range of healthcare apps for older adults. Birkhoff et al. investigated the unique challenges in mobile health app development,

advocating for interprofessional strategies to address privacy and security concerns effectively [6]. Similarly, Pywell et al. investigated the barriers to older adults' uptake of mobile-based mental health solutions, including concerns about data privacy and security, calling for the implementation of robust privacy policies as crucial steps toward protecting personal data [36]. Despite these studies providing insightful information into various aspects of digital health privacy, the focus on healthcare apps specifically designed for older adults remains relatively underexplored. Our study aims to bridge the gap between healthcare app privacy studies and the unique needs of older adults by providing an analysis that reviews regulatory compliance, addresses age-specific concerns, and evaluates the implementation of key privacy concepts.

III. METHODOLOGY

A. Selection of Healthcare Apps

Our list of healthcare apps for older adults was compiled through app stores because after surfing the Internet for a comprehensive list of healthcare apps specific to older adults we weren't able to get a database that already has those healthcare apps. To collect the desired healthcare apps for our study we set inclusion criteria that include apps that are predominantly designed for older adults (age 65 and above) and offer health-related functionalities (telehealth, medication tracking/reminder, vital sign sensors, etc.). We defined our search strategy using keywords like "Older Adults" OR "Seniors" OR "Elderly" OR "Geriatric" in combination with "Health", OR "Care" OR "Healthcare" OR "Telehealth". We used our keywords in the two most popular app stores (Apple Store and Google Play Store) which resulted in 53 apps.

B. App Screening and Anonymization

The collected apps were screened to eliminate duplicates, non-relevant apps and those that lack healthcare-related functions for older adults. In our preliminary screening, we narrowed down our collection from 53 to 28 healthcare apps. Another notable point about our final selection of 28 healthcare apps is that we ensured each app explicitly stated in its app store description that it is specifically designed for older adults. A codebook was created to summarize the key information and also to extract the privacy policies' weblink. To maintain ethical research practices and protect the reputation of the healthcare apps, we decided to use pseudonyms (A1, A2, A3,..., A28) when referencing them in our study. This approach is in line with methods used in related studies [12], [13], [38], which use pseudonyms to protect companies from potential harm while allowing for a transparent discussion of the findings. We have already communicated our findings directly to the app developers, allowing them to fix any issues we uncover.

C. Privacy Risk Assessment Framework (PRAF)

The Privacy Risk Assessment Framework was created to evaluate the privacy risks associated with healthcare apps designed for older adults. The framework is based on reviewing

the privacy policy literature, existing data protection regulations such as HIPAA and GDPR, and considering the unique needs of older adults. PRAF is made up of five key elements, each chosen for its crucial role in protecting older adults' privacy. Due to the importance of regulatory compliance with established privacy standards, which are fundamental to data protection, we selected Regulatory Compliance as a key element. Given the highly confidential nature of health information and the increased vulnerability of older adults to data breaches [8], [17], data security was selected. This element assesses the apps' security measures, including data encryption, access control, and breach protocol. To address the cognitive and physical limitations that may impair older adults' capacity to understand and manage privacy settings [5], [27], usability and accessibility were included. It assesses features like readability, language clarity, and the presence of accessibility features. Data minimization and Retention were essential to reduce privacy risks resulting from unnecessary data retention because this element measures the amount of data collection and storage practices. Third-Party Data sharing was added to measure the degree of control and transparency in data sharing with external entities.

The scoring system for each element represents their importance to the overall privacy risk assessment. The scoring varies among the five elements because some were assessed based on their presence or absence, while others were evaluated according to the level of adherence to specific standards. Regulatory compliance is scored on a scale of 1-4, Data security is scored 1-2 for each criterion, usability and accessibility are scored on a scale of readability of 1-6, and clarity and accessibility on a scale of 1-2 each. Data minimization, retention and third-party data sharing were each scored on a scale of 1-2. A score of 1 indicates non-implementation, while a score of 2 indicates implementation. The overall privacy risk score for each app is achieved by summing the scores from each element. We used the PRAF to assess the 28 healthcare apps based on each app's privacy policy.

D. Privacy Policy Extraction

To carry out a comprehensive analysis of healthcare apps targeted at older adults, we extracted the privacy policies from the collected apps. First, we collected privacy policy URLs from each app, and we created a Python script to automate the scraping of privacy policy content from their respective websites. To ensure the accuracy of the data, we manually reviewed each privacy policy to validate the automated process and capture any information that might have been missed. We employed both methods, acknowledging that automated techniques may occasionally ignore specific aspects so we supplemented with a manual assessment to check the collected data and capture any nuances that the automated process might have missed. The HIPAA privacy rule was established to safeguard the confidentiality and security of health records [55]. However, its coverage is limited to Protected Health Information (PHI) managed by three entities: health plans, healthcare providers, and healthcare clearinghouses [32]. Consequently,

it does not extend to a broader spectrum of situations, leaving personal data held by other uncovered entities unregulated. Although just these three entities are covered by the HIPAA privacy rules, we included all collected apps in our research. This addition guarantees a thorough evaluation because it can be difficult to identify which particular apps are exempted. Furthermore, the GDPR has no such exemptions and requires extensive data protection procedures for all kinds of entities.

IV. RESULTS

Our analysis of the 28 healthcare apps for older adults identified significant variations regarding privacy practices and regulatory compliance. Some of these apps did not explicitly mention HIPAA and GDPR but they had some mentions of other data regulations like the European Economic Area (EEA) rights, California Consumer Privacy Act (CCPA), and other international privacy regulations. Using the Privacy Risk Assessment Framework (PRAF) helped us to discover some key trends and gaps. Among the 28 apps, 7 apps included privacy policies referencing HIPAA, 5 apps mentioned GDPR, 12 apps cited other data protection acts, and 4 apps made no references to any privacy regulations. Additionally, one app, A24, had an inaccessible privacy policy. It is important to note that while some apps claim to adhere to privacy regulations, the actual effectiveness and compliance with these regulations cannot be guaranteed. Therefore, it is crucial to examine the details of each app's privacy policy. Table I shows the apps, usage, regulations, key principles, limitations, readability and privacy risk scores.

A. Common Gaps in Privacy Policies

This demographic frequently has unique challenges understanding complicated terminologies and needs more precise, straightforward explanations of data handling practices. Consequently, this lack of clarity leaves them uncertain about how well their sensitive health data is protected. Another key gap is the lack of accommodations for accessibility in any of the reviewed privacy policies which is a significant concern, considering how important accessibility is for older adults managing age-related conditions.

B. Comparative Analysis of Privacy Practices

Our review of privacy policies for the healthcare apps revealed significant differences in compliance and the implementation of privacy principles.

- **Telehealth Apps:** Apps A1 and A2 that allow remote medical consultations should comply with privacy standards due to the sensitive nature of their data. However, our analysis suggests that only A1 explicitly referred to HIPAA and GDPR, whereas A2 broadly referenced to data privacy standards. User consent, data usage and data encryption policies were described in detail by both apps. However, the difference between A1 and A2's regulatory referencing indicates an opportunity to further standardize privacy policy within this category of healthcare apps.

- **Senior Care and Caregiver Support Apps:** This category's apps displayed a mixed landscape of privacy practices and regulatory compliance. Some apps specifically referred to HIPAA 43%(n=3 out of 7) and thoroughly explained their consent requirement indicating a commitment to user autonomy. Others like A3 and A4 made vague commitments about data security without outlining the safeguards in place which can lead to concerns about the level of protection of sensitive data. The need for better and more standardized privacy processes within this category is highlighted by the inconsistency.
- **Eldercare and Well-being Support Apps:** All apps in this category mentioned various international data protection regulations beyond HIPAA and GDPR, except for A13, which did not reference any regulations. Generally, these apps provided detailed privacy policies addressing data minimization, user consent, and somehow access control. However, the depth of these regulations differed, with some apps providing detailed procedures and others using ambiguous language. This variability in the category implies that although we generally recognise privacy is important for health and eldercare apps, currently, there lacks a clear consistent implementation of good practice.
- **Health Monitoring and Safety Apps:** These apps exhibited good compliance, with 4 out of 6 referencing HIPAA and GDPR. This compliance rate suggests that the apps recognize the necessity of adhering to data regulations due to the medical nature of their data collection during monitoring. It is laudable that apps like A15, A18, and A20 prioritized user consent and data minimization. However, there were obvious gaps in a few key areas. For example, A17 and A19 lacked detailed information on their real-time monitoring and data encryption practices, potentially leaving older adults uncertain about the security of their continuously collected health data. The gap between strong regulatory awareness and inconsistent implementation stresses a need for broader approaches to privacy in health monitoring apps.
- **Healthcare Services App:** A21 and A23 mentioned compliance with HIPAA and GDPR respectively. A23 provided detailed key principles, while A21 focused more on encryption practices and user consent mechanisms but lacked specifics on data retention periods and breach notification procedures. A22, which referenced an alternate privacy policy, failed to address data minimization and encryption protocols. The need for more precise standards on how various healthcare service types should handle data privacy is highlighted by this varied approach to regulatory compliance.
- **Fitness Support Apps:** A27 was the only app in this category to refer to GDPR while the other four apps made no mention of any privacy policies. The lack of HIPAA references may suggest that the developers of fitness apps do not consider the data they collect to be protected health information. To guarantee the complete protection of users' health-related information, this regulatory approach

TABLE I

HEALTHCARE APP PRIVACY POLICY ANALYSIS, READABILITY USING THE SMOG INDEX AND PRIVACY RISK SCORES. LEGEND: YES = ● | PARTIAL = ○ | NO = - | SD = SLIGHTLY DIFFICULT, SWD = SOMEWHAT DIFFICULT, FD = FAIRLY DIFFICULT, D = DIFFICULT, VD = VERY DIFFICULT, P = PROFESSIONAL

Apps	Use	Regulation			Key principles			Limitations/Gaps			Readability		PRAF Scores								
		HIPAA	GDPR	Others	Data minimization	Data Encryption	Access controls	Retention requirements	Breach protocol	Ambiguous language	Vague commitments	3rd party accomms	SMOG	Level	Regulatory Compliance	Data Security	Usability/Accessibility	Minimization/Retention	3rd party sharing	Overall Risk	
A1	Telehealth	●	●	–	●	●	●	●	●	–	–	–	●	13	VD	4	6	7	4	2	23
A2	Telehealth	–	–	●	●	●	●	●	–	○	–	–	●	13.2	VD	2	5	7	4	2	20
A3	Senior care & Caregiver Support	–	–	●	●	–	●	●	●	○	○	–	–	10.9	FD	2	5	7	4	1	19
A4	Senior care & Caregiver Support	–	–	●	●	–	●	●	–	–	○	○	–	14.2	P	2	4	4	3	2	15
A5	Senior care & Caregiver Support	–	–	●	●	–	–	●	–	○	–	–	●	13	VD	2	3	6	4	2	17
A6	Senior care & Caregiver Support	●	–	–	–	●	●	●	–	–	–	–	●	11.5	D	3	5	8	2	2	20
A7	Senior care & Caregiver Support	–	–	●	●	●	●	●	–	–	○	–	●	12.4	D	2	5	7	4	2	20
A8	Senior care & Caregiver Support	●	–	–	–	●	●	●	–	–	○	–	●	11.6	D	3	5	7	2	2	19
A9	Senior care & Caregiver Support	●	–	–	●	–	●	●	●	–	–	–	●	13.4	VD	3	4	7	4	2	20
A10	Eldercare & Well-being Support	–	–	●	●	●	●	●	●	–	–	–	●	12.8	VD	2	6	7	4	2	21
A11	Eldercare & Well-being Support	–	–	●	●	●	●	●	●	–	–	–	●	11.2	FD	2	6	9	4	2	23
A12	Eldercare & Well-being Support	–	–	●	●	●	●	●	–	○	–	–	●	14.4	P	2	5	5	4	2	18
A13	Eldercare & Well-being Support	–	–	–	●	–	–	●	–	○	–	–	●	10.9	FD	1	3	8	3	2	17
A14	Eldercare & Well-being Support	–	–	●	●	●	●	●	–	○	–	–	●	13.2	VD	2	5	6	3	2	18
A15	Health Monitoring & Safety	–	–	●	●	●	●	●	–	–	–	–	●	11.5	D	2	5	8	4	2	21
A16	Health Monitoring & Safety	–	●	–	●	●	●	●	–	–	–	–	●	13	VD	3	5	7	3	2	20
A17	Health Monitoring & Safety	●	–	–	●	–	–	●	●	–	○	–	–	12	D	3	3	7	4	2	19
A18	Health Monitoring & Safety	–	●	–	●	●	●	●	–	–	–	–	●	9.2	SD	3	5	11	3	2	24
A19	Health Monitoring & Safety	–	–	●	●	–	●	●	●	–	○	○	–	11.8	D	2	4	6	4	2	18
A20	Health monitoring & Safety	●	–	–	●	–	●	●	●	–	–	–	●	11.6	D	3	5	8	4	2	22
A21	Healthcare Services	●	–	–	●	●	●	●	–	–	–	–	●	12.9	VD	3	5	7	3	2	20
A22	Healthcare Services	–	–	●	–	–	●	●	–	○	○	–	●	13.3	VD	2	4	5	2	2	15
A23	Healthcare Services	–	●	–	●	●	●	●	●	–	–	–	●	10.6	FD	3	6	9	4	2	24
A24	Fitness Support	–	–	–	–	–	–	–	–	–	–	–	–	-	-	0	0	0	0	0	0
A25	Fitness Support	–	–	–	●	–	–	●	–	○	○	–	●	9.1	SD	1	3	9	3	2	18
A26	Fitness Support	–	–	–	●	–	–	●	–	–	○	–	●	9.6	SWD	1	3	9	3	2	18
A27	Fitness Support	–	●	–	●	●	●	●	–	○	–	–	●	12.1	D	3	5	7	4	2	21
A28	Fitness Support	–	–	–	●	●	●	●	●	○	○	–	●	11.4	FD	1	5	7	4	2	19

may need to be reconsidered given that fitness data can indicate or reveal conditions, especially in older adults.

C. Application of PRAF to Healthcare Apps

1) Regulatory Compliance:

We assessed each app's compliance with GDPR, HIPAA, and other relevant regulations. Out of the 28 apps, 5 apps (17.9%) claimed to be GDPR compliant and 7 apps (25%) specifically stated HIPAA compliance. Additionally, 12 apps (42.9%) made mention of other privacy regulations such as the California Consumer Privacy Act (CCPA), and various international data protection laws. It is interesting to note that 4 apps (14.3%) raised questions about their commitment to standardized data protection because they did not mention adherence to any specific privacy regulations. Apps that comply with both HIPAA and GDPR received 4 points, those complying with either HIPAA or GDPR were assigned 3 points, compliance with other regulations received 2, and non-compliant apps received 1. HIPAA and GDPR received higher scores due to the extensive and significant characteristics of these standards. They both

are esteemed benchmarks in data privacy for healthcare and general data protection.

- 2) **Data Security:** This emerged as an essential component in our framework, with a mean score of 4.5 out of 6 (SD = 1.3). Data encryption, access control, and breach notification protocols were the three main criteria we used to evaluate this component. Each received a score of 2 points for implementation and 1 point for non-implementation. About 57% of apps (16 out of 28) mentioned encryption measures. For instance, A7 stated, "Any payment transactions will be encrypted using SSL." Access control was addressed by 79% of apps (22 out of 28), indicating a focus on user authentication. However, only 21% of apps (6 out of 28) offered comprehensive plans for alerting users to potential data breaches, indicating a significant gap in incident response readiness.

3) Usability and Accessibility:

These were critical components in our Privacy Risk Assessment Framework, with a mean score of 7 out of 12 (SD = 2). We evaluated this based on readability (using the SMOG index) [41], clarity of policies, and the

presence of accessibility features. We scored readability on a scale of 1-6 (Professional=1, Very Difficult=2, Difficult=3, Fairly Difficult=4, Somewhat Difficult=5, Slightly Difficult=6). Policy clarity was scored 2 points for clear, 1 for vague or ambiguous language, and accessibility scored 2 points for present, and 1 for absent. Despite the importance of these features for older adults, none of the apps included specific accessibility options, which are crucial for this demographic.

4) **Data Minimization and Retention:**

These practices were evaluated as part of our Framework, with a mean score of 3.4 out of 4 (SD = 1). Each components were assigned 2 points for implementation and 1 point for non-implementation. While all apps claimed to collect only necessary data, only 86% (24 out of 28) provided specific details on their data minimization practices. For example, A3 stated, “We limit the collection of personal information to what you choose to submit through the use of our services”, but some apps like A6 and A22 did not mention data minimization commitments. Regarding data retention, 57% (16 out of 28) of the apps specified retention periods, with A19’s policy indicating a 5-year retention time. Concerns regarding possible over-collection and indefinite storage of sensitive health information are highlighted by the lack of specificity in data collection extent and retention periods in some of the apps.

5) **Third Party Data Sharing:** This emerged as a critical component in our Framework, with a mean score of 1.9 out of 2 (SD = 0.4). We evaluated this based on transparency of sharing practices, disclosure of third parties, and user control. This was assigned a score of 2 points for implementation and 1 point for non-implementation. Nearly all apps (26 out of 28) included third party sharing details, outlining who, when, and why data might be shared. The emphasis on third-party sharing practices highlights its importance in the overall privacy protection for older adults using healthcare apps.

V. DISCUSSION AND IMPLICATIONS

A. Comprehensibility of Privacy Policies for Older Adults – RQ1

In our analysis, we observed significant challenges with the readability and clarity of privacy policies. These issues raise concerns about the ability of this population to make decisions regarding their health data. Readability was a major concern since about half of the apps under review used complex terminology. The use of choice of phrasing presents a significant barrier to understanding, particularly for older adults whose health and digital literacy vary. To quantify this issue, we evaluated all the collected privacy policies using the SMOG (Simple Measure of Gobbledygook) Index readability test. The SMOG test measures the readability of complex data to make sure the content is clear and understandable to older adults [14], [16], [20]. Using the Readability Formulas calculator [41], we discovered that the average grade level

was roughly 12, which indicates a difficult reading level and the readability score is detailed in Table I and graphically represented in Figure 1. This highlights the necessity for privacy regulations to use accessible language, especially for apps targeted at older adults who can encounter age-related cognitive challenges that impair their ability to understand text. Older adults who might already be cautious of digital privacy issues need clear and detailed information on what personal data is being gathered, how long it will be retained, what security measures are in place, and how their data is being processed.

B. Regulatory Compliance and Gaps in Privacy Protections – RQ2

Our study identified several key principles and protections commonly missing from these apps’ privacy policies. only 4 apps failed to indicate the precise extent of data collected, indicating that data minimization was well addressed. However, only 57% (16 apps) described their data retention periods, and even fewer (21%) outlined the steps involved in notifying users of a data breach. This could mean that many users are not aware of how they would be notified in the event of a data breach. There were only two apps that did not include user consent in their privacy rules, making it the principle that was most often addressed. While HIPAA and GDPR provide important privacy protections, their effectiveness in regulating healthcare apps for older adults seems to be limited. Many healthcare apps are operating in a regulatory gray area due to HIPAA’s narrow focus on covered entities. Our finding that only 25% of apps specifically reference HIPAA implies that a significant portion may fall outside its jurisdiction. The global nature of the app market complicates GDPR enforcement, especially for developers who are not situated in the EU. This could account for our study’s lower GDPR compliance number (17.9%). HIPAA and GDPR fall short of addressing the unique challenges presented by mobile health technologies, such as the ongoing collection of data via wearables or IoT [18], [19], [40], [53], [54], which are becoming more relevant for older adults’ care. There are significant gaps in basic privacy principles and protections, which call for a reassessment and possible expansion of existing regulatory systems to guarantee comprehensive privacy protections for older adults.

C. Policy and Practice Implications – RQ3

Our findings of varying degrees of regulatory compliance highlight the need for a more uniform and comprehensive regulatory framework. One of the most pressing implications of our study is the need to strengthen regulatory frameworks like HIPAA and GDPR. While these bodies provide a solid foundation for data protection, our findings indicate that compliance is inconsistent across different types of healthcare apps. There is a clear need for more specific guidelines tailored to the unique contexts of various app categories, particularly those targeting older adults. Regulatory bodies should consider developing tailored guidelines and increasing

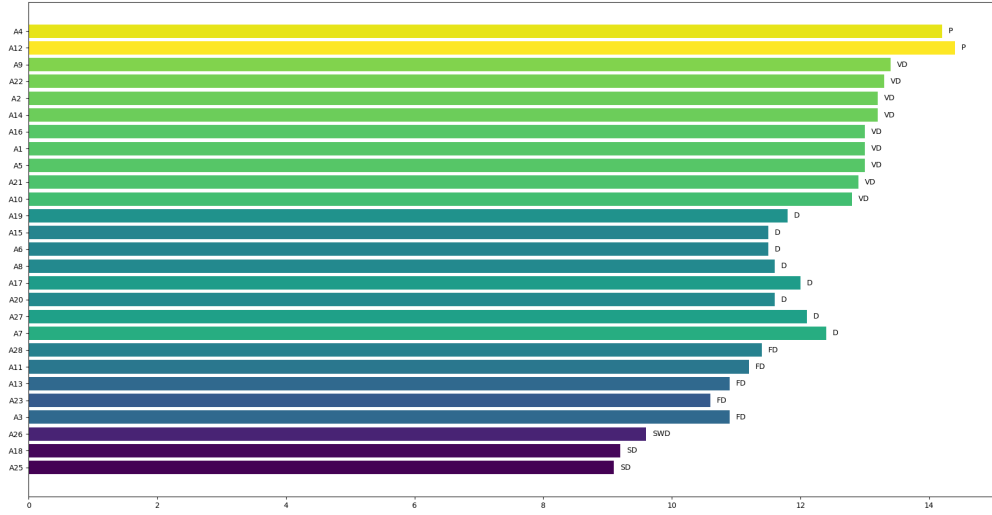


Fig. 1. Readability of Healthcare Apps using the Simple Measure of Gobbledygook (SMOG) Index

regulatory checks and balances for adequate enforcement of privacy policies by designers, this will in turn ensure that all healthcare apps comply with established privacy standards. Beyond regulatory change, our study suggests improvement of the healthcare app industry by developing standardized privacy policy templates that emphasize plain language, clear explanations of data handling, and user rights on data. Also, HIPAA and GDPR should be amended to specifically include mobile health technology and continuous data collection to handle the evolving field of digital health. To give older adults a reliable indication of an app's credibility, we can establish a standardized Privacy Seal or Stamp certification for those that adhere to international privacy standards such as nutrition labels [25]. Our findings highlight the pressing need for industry and regulatory changes to improve data privacy for older adults using healthcare apps. We can make the environment more reliable and secure for older adults by strengthening regulatory frameworks, harmonizing industrial practices, and concentrating on efficient regulatory implementations

D. Implications of PRAF

The framework we introduced offers a thorough assessment of the privacy policies of healthcare apps with a particular emphasis on how well-suited they are for older adults. We can identify major privacy concerns and provide helpful recommendations for enhancing these apps' privacy policies by analyzing the privacy risk scores across critical components. The PRAF's findings show that the evaluated healthcare apps have varying levels of compliance, with some critical areas in need of major improvement. The average regulatory compliance score was 2.2 out of 4, meaning that while some apps comply with regulations like HIPAA and GDPR, many do not. The range of scores from 0 to 4 indicates that different apps apply the regulations in different ways, which could make some older adults more susceptible to privacy breaches. A relative strength that stood out was data security, with an average

score of 4.5 out of 6. This suggests that most of the apps talked about fundamental security features like data encryption and access control. However, inconsistent practices remain a concern, especially about breach notifications. The standard deviation indicates a moderate degree of implementation, with some apps like A1 and A23 scoring high at 6 and others like A25 scoring much lower at 3. Due to the sensitivity of health information, older adults may not be well prepared to handle the consequences resulting from data breaches, thus minor security gaps can be highly harmful.

The mean score for usability and accessibility was 7 out of 12, indicating that while some apps meet the needs of older adults, some do not, which calls for more consistent standards to handle physical and cognitive challenges. This is especially concerning because accidental privacy breaches may occur if older adults find it difficult to understand or use privacy settings. Data Minimization and Retention practices with a mean score of 3.4 out of 4 show relatively consistent implementation across apps. While this is positive, the fact that not all apps receive the highest score implies that some may still be gathering or retaining more data than is required, which might put older adults at greater risk of privacy violations. Finally, Third-Party Data Sharing with a mean score of 1.9 out of 2 appear to be the most consistently implemented component with just two apps failing to include this in their privacy policies. The average overall risk score was 18 out of a possible 28, with scores ranging from 15 (A4) to 24 (A18 and A23). More than half of the apps have scores ranging from 18 to 22 which suggests that they have moderate privacy risks. This finding is very significant given the targeted group and the sensitivity of health-related data. According to our framework analysis, some apps often perform poorly in certain areas but excel in others. This emphasizes the necessity of a comprehensive privacy protection strategy considering older adults' requirements and challenges. App developers and policymakers could help create a safer and more secure

digital health environment that better serves this demographic by addressing the privacy risks highlighted in our study.

Based on our findings, we suggest that targeted regulations be put in place to better meet the privacy demands of older adults who use healthcare apps. It is recommended that policy-makers create standards that take into account the intersection between aging, technology, and health data privacy. It is the responsibility of developers to enhance usability and accessibility by designing user-friendly, age-appropriate interfaces with features like larger text options and simpler language. While maintaining strong data security is essential, usability should not be compromised; innovative ideas are required to strike a balance between the two. PRAF can be a useful tool for continual assessment in identifying and reducing privacy risks for older adults.

VI. LIMITATIONS AND FUTURE WORK

While our sample size is small, it is appropriate given our specific focus on healthcare apps for older adults. The lack of a dedicated “older adults” category in app stores and the absence of pre-existing datasets limited our ability to expand the sample further. It is important to note that our study represents a snapshot of the current landscape, which is subject to change due to the dynamic nature of the mobile app market. Mergers, new developments, or discontinuations of apps could alter this landscape. Additionally, our search results may be influenced by country-specific app store outputs, potentially omitting some apps due to geographic restrictions. We recommend that future research expand on assessing the long-term impact of privacy practices to gain more understanding of how well current measures protect older adults’ data over time.

VII. CONCLUSION

This study provides an assessment of the privacy concerns of healthcare apps designed for older adults using a multi-dimensional Privacy Risk Assessment Framework (PRAF). Our finding shows significant gaps in privacy protection, with many apps falling short of older adults’ unique requirements. A major barrier to understanding privacy policies is the average readability level of grade 12 from our analysis. Additionally, just 25% of apps specifically stated HIPAA compliance, and only 18% cited GDPR, which is a concern for international privacy standards. The gap between real practices and regulatory standards is further demonstrated by the fact that 79% of apps lack breach notification procedures. These findings highlight the critical need for a paradigm shift in the way that privacy is conceived of and applied in healthcare apps for older adults, emphasizing the importance of focused regulations and clearer guidelines that address the intersection of aging, technology, and health data privacy. To better protect older adults, developers must address the unique privacy requirements of this demographic by improving healthcare apps’ transparency, security, and user control in addition to complying with regulatory standards.

VIII. ACKNOWLEDGEMENT

We would also like to thank our participants for this study and acknowledge the Inclusive Security and Privacy-focused Innovative Research in Information Technology (InSPIRIT) Lab at the University of Denver for supporting this work. Any opinions, findings, conclusions, or recommendations expressed in this material are solely those of the authors.

REFERENCES

- [1] Andrick Adhikari, Sanchari Das, and Rinku Dewri. Evolution of composition, readability, and structure of privacy policies over two decades. *Proceedings on Privacy Enhancing Technologies*, 2023.
- [2] Rajindra Adhikari, Deborah Richards, and Karen Scott. Security and privacy issues related to the use of mobile health apps. In *Proceedings of the Australasian Conference on Information Systems (ACIS)*. ACIS, 2014.
- [3] Urs-Vito Albrecht. Opportunities and risks of health apps. In *Law & Net*, pages 417–430. Nomos Verlagsgesellschaft mbH & Co. KG, 2018.
- [4] James Armontrout, John Torous, Marsha Cohen, Dale McNiel, and Renée Binder. Current regulation of mobile mental health applications. *The Journal of the American Academy of Psychiatry and the Law*, 46:204–211, 06 2018.
- [5] Scott Beach, Richard Schulz, Julie Downs, Judith Matthews, Bruce Barron, and Katherine Seelman. Disability, age, and informational privacy attitudes in quality of life technology applications: Results from a national web survey. *ACM Trans. Access. Comput.*, 2(1), may 2009.
- [6] Susan D. Birkhoff and Helene Moriarty. Challenges in mobile health app research: Strategies for interprofessional researchers. *Journal of Interprofessional Education & Practice*, 19:100325, June 2020.
- [7] Sarah R Blenner, Melanie Köllmer, Adam J Rouse, Nadia Daneshvar, Curry Williams, and Lori B Andrews. Privacy policies of android diabetes apps and sharing of health information. *JAMA : the journal of the American Medical Association*, 315(10):1051–1052, 2016.
- [8] Nyteisha Bookert, May Almousa, and Mohd Anwar. Inclusive privacy design for older adults living in ambient assisted living, 2022.
- [9] US Census Bureau. Older People Projected to Outnumber Children for First Time in U.S. History — tinyurl.com. <https://tinyurl.com/babyboomer2030>, 2018. [Accessed 02-02-2024].
- [10] Sanchari Das, Kapil Madathil, Josiah Dykstra, Prashanth Rajivan, Shubha Setty, James T McElligott, Giovanna Hughart, and Daniel Votipka. Privacy and security of telehealth services. In *Proceedings of the Human Factors and Ergonomics Society Annual Meeting*, volume 66, pages 1524–1528. SAGE Publications Sage CA: Los Angeles, CA, 2022.
- [11] Tobias Dehling, Fangjian Gao, Stephan Schneider, and Ali Sunyaev. Exploring the far side of mobile health: Information security and privacy of mobile health apps on ios and android. *JMIR mHealth and uHealth*, 3, 2015.
- [12] D. Denipitiyage, B. Silva, K. Gunathilaka, S. Seneviratne, A. Mahanti, A. Seneviratne, and S. Chawla. Detecting and characterising mobile app metamorphosis in google play store, 2024.
- [13] Karim O. Elish, Haipeng Cai, Daniel Barton, Danfeng Yao, and Barbara G. Ryder. Identifying mobile inter-app communication risks. *IEEE Transactions on Mobile Computing*, 19(1):90–102, 2020.
- [14] Fatimah Z Fahimuddin, Sanam Sidhu, and Anubhav Agrawal. The readability of online patient education materials from major obstetrics and gynecology societies [17p]. *Obstetrics & Gynecology*, 133:174–175, 2019.
- [15] Ming Fan, Le Yu, Sen Chen, Hao Zhou, Xiapu Luo, Shuyue Li, Yang Liu, Jun Liu, and Ting Liu. An empirical evaluation of gdpr compliance violations in android mhealth apps. *2020 IEEE 31st International Symposium on Software Reliability Engineering (ISSRE)*, pages 253–264, 2020.
- [16] Emmen Farooq, M. Ahmad Nawaz UI Ghani, Zuhair Naseer, and Shaukat Iqbal. Privacy policies’ readability analysis of contemporary free healthcare apps. In *2020 14th International Conference on Open Source Systems and Technologies (ICOSST)*, pages 1–7, 2020.
- [17] Ari B. Friedman, Chris Pathmanabhan, Allen Glicksman, George Demiris, Anne R. Cappola, and Matthew S. McCoy. Addressing online health privacy risks for older adults: A perspective on ethical considerations and recommendations. *Gerontology and Geriatric Medicine*, 8:23337214221095705, 2022. PMID: 35493968.

- [18] Shakthidhar Gopavaram, Jayati Dev, Sanchari Das, and L Jean Camp. Iot marketplace: Willingness-to-pay vs. willingness-to-accept. In *Proceedings of the 20th Annual Workshop on the Economics of Information Security (WEIS 2021)*, 2021.
- [19] Hilda Hadan, Nicolas Serrano, Sanchari Das, and L Jean Camp. Making iot worthy of human trust. In *TPRC47: The 47th Research Conference on Communication, Information and Internet Policy*, 2019.
- [20] Amy S. Hedman. Using the smog formula to revise a health-related document. *American Journal of Health Education*, 39(1):61–64, 2008.
- [21] Victoria Hordern. Data protection compliance in the age of digital health. *European Journal of Health Law*, 23(3):248 – 264, 2016.
- [22] B. H.Sampat, Brinda Hansraj Sampat, and Bala Prabhakar. Privacy risks and security threats in mhealth apps. *Journal of international technology and information management.*, 26(4), 2017-12-01.
- [23] Kit Huckvale, John B Torous, and Mark Erik Larsen. Assessment of the data sharing and privacy practices of smartphone apps for depression and smoking cessation. *JAMA Network Open*, 2, 2019.
- [24] Pranay Kapoor, Rohan Pagey, Mohammad Mannan, and Amr M. Youssef. Silver surfers on the tech wave: Privacy analysis of android apps for the elderly. In *Security and Privacy in Communication Networks*, 2022.
- [25] Patrick Gage Kelley, Joanna Bresee, Lorrie Faith Cranor, and Robert W. Reeder. A “nutrition label” for privacy. In *Proceedings of the 5th Symposium on Usable Privacy and Security*, SOUPS ’09, New York, NY, USA, 2009. Association for Computing Machinery.
- [26] Hadi Kharrazi, Robin Chisholm, Dean VanNasdale, and Benjamin Thompson. Mobile personal health records: An evaluation of features and functionality. *International journal of medical informatics*, 81 9:579–93, 2012.
- [27] Alexis N Kuerbis, Adina Mulliken, Frederick J Muench, Alison A. Moore, and Daniel S Gardner. Older adults and mobile technology: Factors that enhance and inhibit utilization in the context of behavioral health. In *Computer Science, Sociology, Medicine*, 2017.
- [28] Francoise A. Marvel, Paul Dowell, and Sarah E. Mossburg. Emergence of application-based healthcare. *PSNet [internet]*, 2022.
- [29] Callie Monroe, Faiza Tazi, and Sanchari Das. Location data and covid-19 contact tracing: How data privacy regulations and cell service providers work in tandem. In *Proceedings of the Workshop on Usable Security and Privacy (USEC)*, 2021.
- [30] Joana Muchagata and Ana Ferreira. Translating gdpr into the mhealth practice. In *2018 International Carnahan Conference on Security Technology (ICCST)*, pages 1–5, 2018.
- [31] Trix Mulder. Health apps, their privacy policies and the gdpr. *European journal of law and technology*, 10(1), 2019.
- [32] National Institutes of Health. HIPAA Privacy Rule and Its Impacts on Research.
- [33] Achilleas Papageorgiou, Michael Strigkos, Eugenia A. Politou, Efthimios Alepis, Agusti Solanas, and Constantinos Patsakis. Security and privacy analysis of mobile health applications: The alarming state of practice. *IEEE Access*, 6:9390–9403, 2018.
- [34] Lisa Parker, Tanya Karliychuk, Donna M. Gillies, Barbara J. Mintzes, Melissa Raven, and Quinn Grundy. A health app developer’s guide to law and policy: a multi-sector policy analysis. *BMC Medical Informatics and Decision Making*, 17, 2017.
- [35] The European Parliament and the Council of the European Union. Regulation (eu) 2016/679 of the european parliament and of the council of 27 april 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing directive 95/46/ec (general data protection regulation). *Official Journal of the European Union*, L119, 2016.
- [36] Jake Pywell, Santosh Vijaykumar, Alyson Dodd, and Lynne Coventry. Barriers to older adults’ uptake of mobile-based mental health interventions. *DIGITAL HEALTH*, 6:205520762090542, January 2020.
- [37] Q.Grunsky, Quinn Grundy, Kellia Chiu, Fabian Held, Andrea Continella, Lisa Bero, and Ralph Holz. Data sharing practices of medicines related apps and the mobile ecosystem: traffic, content, and network analysis. *BMJ : British medical journal.*, 364(1920), 2019-03-20.
- [38] Lisa Rosenfeld, John Torous, and Ipsit V. Vahia. Data security and privacy in apps for dementia: An analysis of existing privacy policies. *The American Journal of Geriatric Psychiatry*, 25(8):873–877, 2017. Use of Technology in Geriatric Mental Health.
- [39] Bilash Saha, Sharaban Tahora, Abdul Barek, and Hossain Shahriar. Hipaachecker: The comprehensive solution for hipaa compliance in android mhealth apps. *2023 IEEE 47th Annual Computers, Software, and Applications Conference (COMPSAC)*, pages 1822–1827, 2023.
- [40] Suleiman Saka and Sanchari Das. Safeguarding in the internet of things age: A comprehensive review of security and privacy risks for older adults. *Innovation in Aging*, 7(Suppl 1):819, 2023.
- [41] Brian Scott. Readability Scoring System — readabilityformulas.com. <https://readabilityformulas.com/readability-scoring-system.php#formulaResults>. [Accessed 05-07-2024].
- [42] Conor Stewart. Total mHealth market size worldwide 2025 forecast — Statista — tinyurl.com. <https://tinyurl.com/mHealthgmarket>, 2018. [Accessed 13-03-2024].
- [43] Aishwarya Surani, Amani Bawaked, Matthew Wheeler, Braden Kelsey, Nikki Roberts, David Vincent, and Sanchari Das. Security and privacy of digital mental health: An analysis of web services and mobile applications. In *IFIP Annual Conference on Data and Applications Security and Privacy*, pages 319–338. Springer, 2023.
- [44] Aishwarya Surani and Sanchari Das. Understanding privacy and security postures of healthcare chatbots. 2022.
- [45] Faiza Tazi and Sanchari Das. Evaluating telehealth for women in mexico: Privacy, usability, and integration challenges in remote healthcare. *Usability, and Integration Challenges in Remote Healthcare (July 15, 2024)*, 2024.
- [46] Faiza Tazi, Josiah Dykstra, Prashanth Rajivan, Kapil Chalil Madathil, Jiovanne Hughart, James McElligott, Daniel Votipka, and Sanchari Das. Improving privacy and security of telehealth. *Communications of the ACM*, 67(9):27–30, 2024.
- [47] Faiza Tazi, Josiah Dykstra, Prashanth Rajivan, and Sanchari Das. Sok: Evaluating privacy and security vulnerabilities of patients’ data in healthcare. In *International workshop on socio-technical aspects in security*, pages 153–181. Springer, 2022.
- [48] Faiza Tazi, Josiah Dykstra, Prashanth Rajivan, and Sanchari Das. “ we have no security concerns”: Understanding the privacy-security nexus in telehealth for audiologists and speech-language pathologists: Understanding the privacy-security nexus in telehealth. In *Proceedings of the CHI Conference on Human Factors in Computing Systems*, pages 1–20, 2024.
- [49] Faiza Tazi, Josiah Dykstra, Prashanth Rajivan, and Sanchari Das. Exploring technological challenges in telehealth for allied healthcare practices. In *Proceedings of the Human Factors and Ergonomics Society Annual Meeting*, page 10711813241262974. SAGE Publications Sage CA: Los Angeles, CA, 2024.
- [50] Faiza Tazi, Archana Nandakumar, Josiah Dykstra, Prashanth Rajivan, and Sanchari Das. Privacy, security, and usability tradeoffs of telehealth from practitioners’ perspectives. In *Proceedings of the Human Factors and Ergonomics Society Annual Meeting*, volume 67, pages 1862–1867. SAGE Publications Sage CA: Los Angeles, CA, 2023.
- [51] Faiza Tazi, Archana Nandakumar, Josiah Dykstra, Prashanth Rajivan, and Sanchari Das. Sok: Analysis of user-centered studies focusing on healthcare privacy & security. *arXiv preprint arXiv:2306.06033*, 2023.
- [52] Faiza Tazi, Archana Nandakumar, Josiah Dykstra, Prashanth Rajivan, and Sanchari Das. Sok: Analyzing privacy and security of healthcare data from the user perspective. *ACM Transactions on Computing for Healthcare*, 5(2):1–31, 2024.
- [53] Faiza Tazi, Suleiman Saka, Griffin Opp, Shradha Neupane, Sanchari Das, Lorenzo De Carli, and Indrakshi Ray. Accessibility evaluation of iot android mobile companion apps. In *Extended Abstracts of the 2023 CHI Conference on Human Factors in Computing Systems*, pages 1–7, 2023.
- [54] Otily Toutsoy, Sanchari Das, and Kevin Kornegay. Exploring the security issues in home-based iot devices through denial of service attacks. In *2021 IEEE SmartWorld, Ubiquitous Intelligence & Computing, Advanced & Trusted Computing, Scalable Computing & Communications, Internet of People and Smart City Innovation (SmartWorld/SCALCOM/UIC/ATC/IOP/SCI)*, pages 407–415. IEEE, 2021.
- [55] U.S. Department of Health & Human Services. Summary of the HIPAA Privacy Rule.
- [56] Fatma Zubaydi, Ayat Saleh, Fadi Aloul, and Assim Sagahyoon. Security of mobile health (mhealth) systems. In *2015 IEEE 15th International Conference on Bioinformatics and Bioengineering (BIBE)*, pages 1–5, 2015.